

Vulnerability Enrichment & Prioritization Summary

Client: Acme Financial Services

Objective: Evidence-Based Vulnerability Prioritization

1. Methodology

To provide Acme Financial Services with actionable, intelligence-driven risk prioritization, we built an automated enrichment pipeline leveraging VulnCheck's enterprise APIs and industry-standard probability metrics.

- **Asset Modeling & Extraction:** We ingested the provided sample list of four Common Platform Enumeration (CPE) URIs representing Acme's edge and infrastructure footprint (Palo Alto PAN-OS, Smart HMI WebIQ, Ivanti vTM, and Microsoft Windows Server 2025). These were passed to the VulnCheck `/cpe` API to establish a baseline vulnerability register.
- **Intelligence Enrichment:** Each extracted CVE was processed through VulnCheck's `/index/vulncheck-nvd2` and `/index/exploits` indices. This provided the "single source of truth" for technical metrics (CVSS v3), exploit maturity, timeline data (e.g., weaponization dates), and granular threat actor attribution.
- **Probability Scoring:** To augment the deterministic VulnCheck data, we executed a batched call to the FIRST.org API to append the Exploit Prediction Scoring System (EPSS) probability score and percentile for every vulnerability.
- **Evidence-Based Prioritization:** We mapped the enriched dataset against the VulnCheck Evidence-Based Vulnerability Prioritization pyramid. Vulnerabilities were tiered top-down from highest real-world risk (Known Ransomware/Botnet/APT campaigns) down to theoretical risk (All Other Vulnerabilities).

2. Key Findings

The enrichment pipeline successfully queried the target assets and identified a total exposure of **1,331 CVEs**. By moving away from theoretical severity (CVSS) and focusing on real-world exploitability, we condensed this massive register into a highly actionable remediation list.

- **Asset Risk Distribution:** The vast majority of Acme's legacy vulnerability debt resides on the Microsoft Windows Server 2025 asset (1,292 CVEs). Palo Alto PAN-OS accounted for 38 CVEs, WebIQ accounted for 1 CVE, and Ivanti Virtual Traffic Management returned 0 CVEs.
- **The "VulnCheck Advantage":** Out of the 1,331 total vulnerabilities, 28 are confirmed to be actively exploited in the wild (VulnCheck KEV). Crucially, **6 of these actively exploited CVEs are entirely missing from the CISA KEV catalog**. Relying solely on CISA for known-exploited

alerting would have left Acme with a massive blind spot affecting their Windows Server and WebIQ infrastructure.

- **Weaponized Imminence:** Beyond the 28 actively exploited issues, the telemetry identified an additional **10 Weaponized CVEs**. These vulnerabilities have reliable, functional exploit code available to the public, representing the most immediate staging ground for future threat actor campaigns.
- **Threat Actor Targeting:** While explicit programmatic categorization placed the 28 KEVs into the "Unattributed KEV" tier, the granular threat intelligence strings reveal severe targeting. Acme's exposed vulnerabilities are routinely exploited by high-profile adversaries, including traces of *Fancy Bear*, *Qilin*, *Veiled Panda*, and multiple China-attributed clusters.

3. Assumptions & Limitations

- **Perimeter Context:** The prioritization model assumes all four provided CPEs are internet-facing or mission-critical to Acme Financial operations. Because internal compensating controls (like WAFs or network segmentation) are unknown, the tiering assumes a "worst-case" network exposure.
- **Categorization Mapping:** The automated assignment algorithm in the pipeline maps vulnerabilities to the "Threat Actors (APT)" or "Ransomware" tiers strictly if the VulnCheck API returns those specific top-level boolean tags in the JSON response. Because the API successfully identified adversaries (e.g., *Fancy Bear*) under the `reported_exploitation` array rather than the `threat_actors` explicit array, these highly critical CVEs defaulted down to the "Unattributed KEV" tier.
- **Remediation Direction:** The generated priority tiers dictate *what* to fix first (the 28 KEVs, followed by the 10 Weaponized CVEs), assuming Acme has the bandwidth to address the top of the pyramid. If bandwidth is highly constrained, the EPSS percentiles appended to the dataset should be used as a secondary filter to rank the KEVs by immediate probability of next-day exploitation.